
Intégration du framework MITRE ATT&CK dans un écosystème MCP pour la détection

Quand l'intelligence artificielle apprend à citer ses sources

Kamil Saleh

Université du Québec à Chicoutimi (UQAC)

Projet mené avec la collaboration d'Hydro-Québec de l'UQAC

20 août 2026

Le chemin de cette présentation

1. **État de l'art** que sait-on déjà, et que manque-t-il ?
2. Le Model Context Protocol, expliqué simplement
3. Notre serveur MCP : fonctionnalités, outils, démonstration
4. Les problèmes rencontrés et corrigés
5. Ce qui reste à faire : évaluation et sécurisation

**Suffirait-il de remplacer nos analystes
en cybersécurité par l'intelligence artificielle ?**

Suffirait-il de remplacer nos analystes en cybersécurité par l'intelligence artificielle ?

- Une IA sait lire et expliquer une attaque mais sait-elle prendre la bonne décision quand la vérité compte ?

Suffirait-il de remplacer nos analystes en cybersécurité par l'intelligence artificielle ?

- Une IA sait lire et expliquer une attaque mais sait-elle prendre la bonne décision quand la vérité compte ?
- Comment la forcer à s'appuyer sur des faits vérifiables, plutôt que sur sa mémoire ?

Suffirait-il de remplacer nos analystes en cybersécurité par l'intelligence artificielle ?

- Une IA sait lire et expliquer une attaque mais sait-elle prendre la bonne décision quand la vérité compte ?
- Comment la forcer à s'appuyer sur des faits vérifiables, plutôt que sur sa mémoire ?
- C'est exactement le rôle du Model Context Protocol (MCP) et c'est l'objet de ce projet.

La réalité d'un centre d'opérations de sécurité (SOC)

4 484

alertes reçues par jour,
en moyenne, par équipe SOC

(Vectra, 2023)

67 %

de ces alertes ne sont
jamais traitées

(Vectra, 2023)

1 sur 2

analystes songent à quitter
le domaine, épuisés

(Splunk, 2025)

Le danger d'un SOC moderne n'est pas le manque d'information : c'est l'excès d'information non triée et l'épuisement des humains qui doivent la trier.

Les LLM : un copilote brillant... qui ne dit jamais « je ne sais pas »

- Les grands modèles de langage (LLM) savent lire, résumer et expliquer une alerte en langage clair une aide précieuse au triage.

Les LLM : un copilote brillant... qui ne dit jamais « je ne sais pas »

- Les grands modèles de langage (LLM) savent lire, résumer et expliquer une alerte en langage clair une aide précieuse au triage.
- Mais quand l'information leur manque, ils produisent la suite la plus *plausible* : c'est l'hallucination .

Les LLM : un copilote brillant... qui ne dit jamais « je ne sais pas »

- Les grands modèles de langage (LLM) savent lire, résumer et expliquer une alerte en langage clair une aide précieuse au triage.
- Mais quand l'information leur manque, ils produisent la suite la plus *plausible* : c'est l'hallucination .
- En cybersécurité, une technique d'attaque inventée, c'est une enquête orientée vers la mauvaise cible pendant que la vraie attaque continue.

Les LLM : un copilote brillant... qui ne dit jamais « je ne sais pas »

- Les grands modèles de langage (LLM) savent lire, résumer et expliquer une alerte en langage clair une aide précieuse au triage.
- Mais quand l'information leur manque, ils produisent la suite la plus *plausible* : c'est l'hallucination .
- En cybersécurité, une technique d'attaque inventée, c'est une enquête orientée vers la mauvaise cible pendant que la vraie attaque continue.

Le problème n'est pas le LLM lui même mais c'est son ancrage dans les faits.

Notre réponse : brancher l'IA sur la source officielle

- **MITRE ATT&CK** : l'encyclopédie mondiale, libre et maintenue, des modes opératoires des attaquants « le dictionnaire du cambrioleur ».
- **MCP** (*Model Context Protocol*) : le standard ouvert qui branche un modèle d'IA sur une source de données « le port USB-C de l'IA ».



Notre réponse : brancher l'IA sur la source officielle

- **MITRE ATT&CK** : l'encyclopédie mondiale, libre et maintenue, des modes opératoires des attaquants « le dictionnaire du cambrioleur ».
- **MCP** (*Model Context Protocol*) : le standard ouvert qui branche un modèle d'IA sur une source de données « le port USB-C de l'IA ».

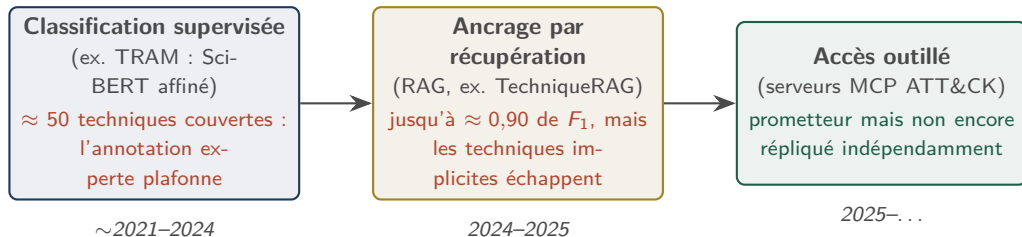


L'agent ne récite plus de mémoire : chaque technique qu'il avance est allée chercher, par un appel vérifiable, dans le référentiel officiel.

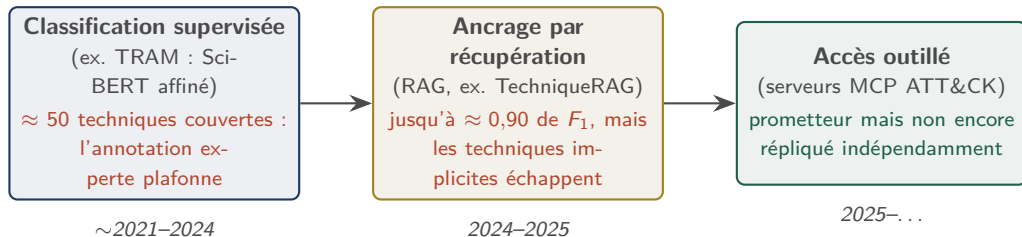
Pourquoi Hydro-Québec, pourquoi maintenant

- Les plateformes commerciales de détection sont des boîtes noires : la logique appartient au fournisseur, l'audit est impossible.
- Pour une infrastructure critique, la loi canadienne sur la protection des cybersystèmes essentiels (loi C-26) exige une maîtrise technique auditable.
- Un serveur MCP développé à l'interne est un actif souverain : l'organisation le possède, le lit, le modifie et le journalise.

État de l'art (1/3) - Trois générations pour automatiser le *mapping*



État de l'art (1/3) - Trois générations pour automatiser le *mapping*



Le *mapping* n'est pas de la reconnaissance de mots-clés : c'est un raisonnement, qui exige un appui sur une base fiable. Chaque génération rapproche le modèle de la source.

État de l'art (2/3) - Que valent les LLM face aux attaques ?

- Détecter : oui. Ancrés sur des journaux, ils dépassent les classifieurs classiques ($F_1 \approx 0,93$ contre $\approx 0,56$ pour XGBoost) et savent expliquer leurs verdicts.

État de l'art (2/3) - Que valent les LLM face aux attaques ?

- Détecter : oui. Ancrés sur des journaux, ils dépassent les classifieurs classiques ($F_1 \approx 0,93$ contre $\approx 0,56$ pour XGBoost) et savent expliquer leurs verdicts.
- Se tromper : oui aussi. L'hallucination demeure le risque central l'ancrage la *réduit*, il ne l'*élimine* pas.

État de l'art (2/3) - Que valent les LLM face aux attaques ?

- Détecter : oui. Ancrés sur des journaux, ils dépassent les classifieurs classiques ($F_1 \approx 0,93$ contre $\approx 0,56$ pour XGBoost) et savent expliquer leurs verdicts.
- Se tromper : oui aussi. L'hallucination demeure le risque central l'ancrage la *réduit*, il ne l'*élimine* pas.
- Sur le terrain (10 mois d'observation en SOC réel) : les analystes utilisent le LLM pour *comprendre*, pas pour *décider*.

État de l'art (2/3) - Que valent les LLM face aux attaques ?

- Détecter : oui. Ancrés sur des journaux, ils dépassent les classifieurs classiques ($F_1 \approx 0,93$ contre $\approx 0,56$ pour XGBoost) et savent expliquer leurs verdicts.
- Se tromper : oui aussi. L'hallucination demeure le risque central l'ancrage la *réduit*, il ne l'*élimine* pas.
- Sur le terrain (10 mois d'observation en SOC réel) : les analystes utilisent le LLM pour *comprendre*, pas pour *décider*.

Réponse à notre question d'ouverture

La littérature converge : le LLM est une **augmentation de l'analyste**, pas son remplacement.

État de l'art (3/3) - Le revers : la sécurité du MCP lui-même

- Un LLM isolé qui se trompe produit du texte ; branché à des outils, il peut produire une action.

État de l'art (3/3) - Le revers : la sécurité du MCP lui-même

- Un LLM isolé qui se trompe produit du texte ; branché à des outils, il peut produire une action.
- Empoisonnement d'outils : 36,5 % de réussite moyenne sur des serveurs MCP réels et les modèles *les plus capables* sont les plus vulnérables (MCPTox, AAAI 2026).

État de l'art (3/3) - Le revers : la sécurité du MCP lui-même

- Un LLM isolé qui se trompe produit du texte ; branché à des outils, il peut produire une action.
- Empoisonnement d'outils : 36,5 % de réussite moyenne sur des serveurs MCP réels et les modèles *les plus capables* sont les plus vulnérables (MCPTox, AAAI 2026).
- Vulnérabilités avérées (CVE-2025-6514, gravité 9,6/10) ; des garde-fous de la spécification restent optionnels (*should* $\neq$ *must*).

État de l'art (3/3) - Le revers : la sécurité du MCP lui-même

- Un LLM isolé qui se trompe produit du texte ; branché à des outils, il peut produire une action.
- Empoisonnement d'outils : 36,5 % de réussite moyenne sur des serveurs MCP réels et les modèles *les plus capables* sont les plus vulnérables (MCPTox, AAAI 2026).
- Vulnérabilités avérées (CVE-2025-6514, gravité 9,6/10) ; des garde-fous de la spécification restent optionnels (*should* $\neq$ *must*).
- Constat de la NSA (2026) : la prolifération du MCP a devancé son modèle de sécurité.

État de l'art (3/3) - Le revers : la sécurité du MCP lui-même

- Un LLM isolé qui se trompe produit du texte ; branché à des outils, il peut produire une action.
- Empoisonnement d'outils : 36,5 % de réussite moyenne sur des serveurs MCP réels et les modèles *les plus capables* sont les plus vulnérables (MCPTox, AAAI 2026).
- Vulnérabilités avérées (CVE-2025-6514, gravité 9,6/10) ; des garde-fous de la spécification restent optionnels (*should* $\neq$ *must*).
- Constat de la NSA (2026) : la prolifération du MCP a devancé son modèle de sécurité.

Un outil d'aide à la détection qui deviendrait lui-même un vecteur d'attaque serait une régression d'où le volet sécurisation de ce projet.

Synthèse de la revue

Ce que la littérature établit

- L'ancrage dans une base fiable compte plus que la taille du modèle.
- Le LLM augmente l'analyste ; il ne le remplace pas.
- Les risques du MCP sont réels et documentés.

Ce qu'elle laisse ouvert

- Modèles évalués souvent déjà dépassés au moment de la publication.
- Corpus : du texte CTI en anglais rien sur les journaux industriels (OT/ICS).
- Benchmarks publics exposés à la contamination ; fiabilité résiduelle non caractérisée pour la décision critique.
- Latence temps réel et sécurité MCP en milieu régulé : non évaluées.

Synthèse de la revue

Ce que la littérature établit

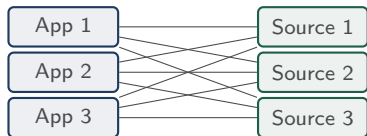
- L'ancrage dans une base fiable compte plus que la taille du modèle.
- Le LLM augmente l'analyste ; il ne le remplace pas.
- Les risques du MCP sont réels et documentés.

Ce qu'elle laisse ouvert

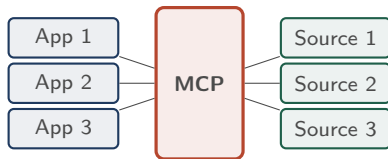
- Modèles évalués souvent déjà dépassés au moment de la publication.
- Corpus : du texte CTI en anglais rien sur les journaux industriels (OT/ICS).
- Benchmarks publics exposés à la contamination ; fiabilité résiduelle non caractérisée pour la décision critique.
- Latence temps réel et sécurité MCP en milieu régulé : non évaluées.

C'est dans ces angles morts que notre projet s'installe et tout commence par comprendre le MCP.

Le MCP en une idée : d'un problème de câbles à une prise universelle

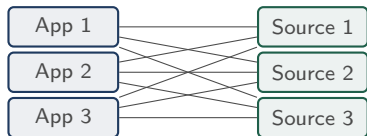


*Sans standard : un connecteur
sur mesure par couple ($M \times N$)*

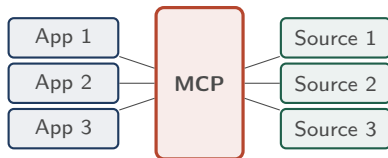


*Avec le MCP : une implémentation
par côté ($M + N$)*

Le MCP en une idée : d'un problème de câbles à une prise universelle



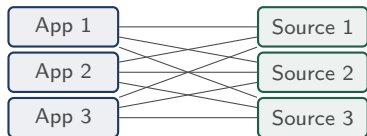
*Sans standard : un connecteur
sur mesure par couple ($M \times N$)*



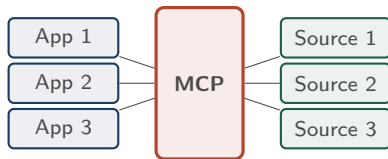
*Avec le MCP : une implémentation
par côté ($M + N$)*

- Standard ouvert : publié par Anthropic (novembre 2024), adopté depuis par les grands fournisseurs concurrents.

Le MCP en une idée : d'un problème de câbles à une prise universelle



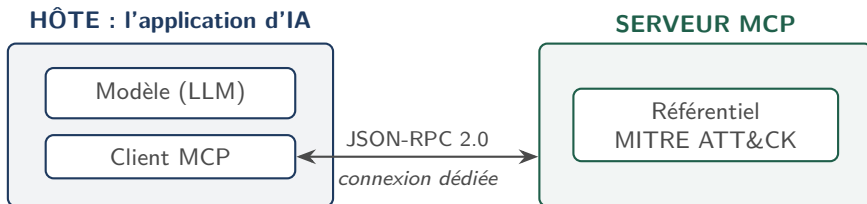
*Sans standard : un connecteur
sur mesure par couple ($M \times N$)*



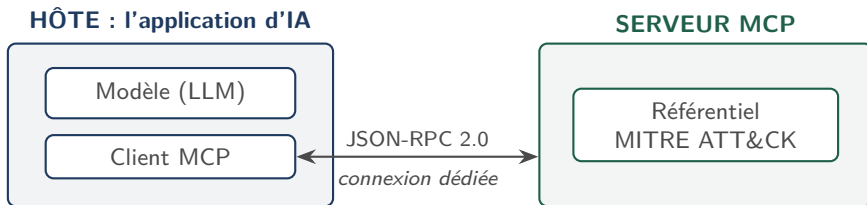
*Avec le MCP : une implémentation
par côté ($M + N$)*

- Standard ouvert : publié par Anthropic (novembre 2024), adopté depuis par les grands fournisseurs concurrents.
- Gouvernance neutre : projet confié fin 2025 à une fondation sous l'égide de la Linux Foundation personne n'en est captif.

Trois rôles et un point de contrôle unique



Trois rôles et un point de contrôle unique



Le serveur ne parle jamais directement au modèle : tout transite par le client, donc par l'hôte un guichet unique où chaque appel peut être validé, filtré, soumis à confirmation humaine.

Trois primitives et surtout : qui décide de quoi

Outils (*tools*)

Fonctions que le serveur exécute à la demande (ex. `rechercher_technique`).

Qui décide : le modèle.

Ressources

Contenus fournis en lecture au contexte (ex. une fiche de technique).

Qui décide : l'application.

Prompts

Modèles d'interaction préconfigurés (ex. « analyse cette alerte »).

Qui décide : l'utilisateur.

Trois primitives et surtout : qui décide de quoi

Outils (*tools*)

Fonctions que le serveur exécute à la demande (ex. `rechercher_technique`).

Qui décide : le modèle.

Ressources

Contenus fournis en lecture au contexte (ex. une fiche de technique).

Qui décide : l'application.

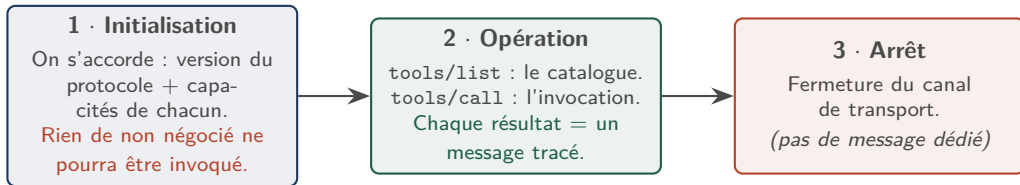
Prompts

Modèles d'interaction préconfigurés (ex. « analyse cette alerte »).

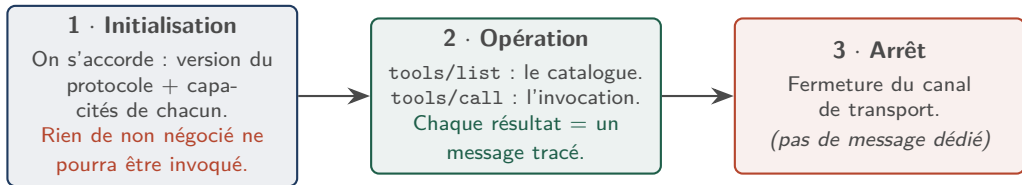
Qui décide : l'utilisateur.

Cette répartition n'est pas un détail technique : c'est un modèle de contrôle elle délimite ce que le modèle peut, et ne peut pas, provoquer.

Un échange MCP : trois phases, aucune improvisation



Un échange MCP : trois phases, aucune improvisation



L'idée essentielle

Le modèle ne fabrique pas les données qu'il présente : il les obtient par des messages identifiés et journalisables. C'est la propriété qui motive tout notre projet.

Deux façons de se parler : stdio et Streamable HTTP

stdio la même pièce

- Le serveur est un sous-processus local du client.
- Aucune exposition réseau ; cycle de vie adossé au processus parent.
- Cas d'usage : poste d'analyste, développement.

Streamable HTTP l'appel réseau

- Le serveur est un service réseau : un point d'entrée, plusieurs clients.
- Exposition réelle : certaines protections exigées, d'autres seulement *recommandées*.
- Cas d'usage : intégration à l'infrastructure d'un SOC.

Deux façons de se parler : stdio et Streamable HTTP

stdio la même pièce

- Le serveur est un sous-processus local du client.
- Aucune exposition réseau ; cycle de vie adossé au processus parent.
- Cas d'usage : poste d'analyste, développement.

Streamable HTTP l'appel réseau

- Le serveur est un service réseau : un point d'entrée, plusieurs clients.
- Exposition réelle : certaines protections exigées, d'autres seulement *recommandées*.
- Cas d'usage : intégration à l'infrastructure d'un SOC.

- Même format de message dans les deux cas : changer de transport ne change ni les outils, ni leur logique mais change la surface d'attaque (chapitre sécurisation).

Deux façons de se parler : stdio et Streamable HTTP

stdio la même pièce

- Le serveur est un sous-processus local du client.
- Aucune exposition réseau ; cycle de vie adossé au processus parent.
- Cas d'usage : poste d'analyste, développement.

Streamable HTTP l'appel réseau

- Le serveur est un service réseau : un point d'entrée, plusieurs clients.
- Exposition réelle : certaines protections exigées, d'autres seulement *recommandées*.
- Cas d'usage : intégration à l'infrastructure d'un SOC.

- Même format de message dans les deux cas : changer de transport ne change ni les outils, ni leur logique mais change la surface d'attaque (chapitre sécurisation).
- Protocole en évolution rapide : révision stable 2025-11-25 ; une révision 2026-07-28 en cours de finalisation.

Soyons précis : ce que le MCP apporte et ce qu'il ne fait pas

Ce qu'il apporte au projet

- **Interopérabilité** : un serveur conforme se branche sur tout hôte conforme.
- **Ancrage vérifiable** : un identifiant retourné provient nécessairement du référentiel.
- **Traçabilité** : chaque appel est journalisable l'auditabilité qu'exige la LPCE (ex-C-26).
- **Souveraineté** : la logique de détection appartient à l'organisation.

Ce qu'il ne fait pas

- Il ne rend pas le modèle plus intelligent : il normalise l'*échange de contexte*, pas le raisonnement.
- Il ne garantit pas la qualité du mapping c'est la conception de notre serveur.
- Il ne garantit pas la sécurité applicative c'est notre volet sécurisation.

Soyons précis : ce que le MCP apporte et ce qu'il ne fait pas

Ce qu'il apporte au projet

- **Interopérabilité** : un serveur conforme se branche sur tout hôte conforme.
- **Ancrage vérifiable** : un identifiant retourné provient nécessairement du référentiel.
- **Traçabilité** : chaque appel est journalisable l'auditabilité qu'exige la LPCE (ex-C-26).
- **Souveraineté** : la logique de détection appartient à l'organisation.

Ce qu'il ne fait pas

- Il ne rend pas le modèle plus intelligent : il normalise l'*échange de contexte*, pas le raisonnement.
- Il ne garantit pas la qualité du mapping c'est la conception de notre serveur.
- Il ne garantit pas la sécurité applicative c'est notre volet sécurisation.

Le MCP fournit le canal pas la méthode. Voyons maintenant le serveur que nous avons construit dessus.

Notre serveur MCP : la carte d'identité

Ce qu'il est

- **Un fichier Python unique**, bibliothèque standard seulement auditable ligne par ligne, zéro dépendance tierce.
- Transport stdio local (mode développement) l'exposition réseau attend le volet sécurisation.
- **Lecture seule** : aucun outil d'écriture le modèle ne peut pas polluer la source de vérité.

Ce qu'il sert

- Base hybride Enterprise + ICS (ATT&CK 19.1) : 27 tactiques, 794 techniques, 176 groupes, 827 logiciels, 96 mitigations.
- 14 outils en 4 familles : cycle de mapping, consultation, référentiel interne, exploitation.
- Chaque réponse datée (`db_version`) + journal d'audit JSONL.

Notre serveur MCP : la carte d'identité

Ce qu'il est

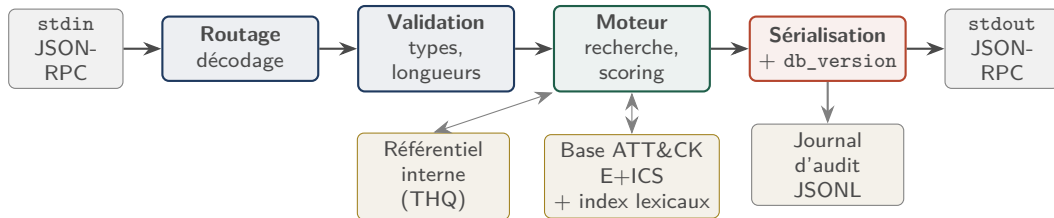
- **Un fichier Python unique**, bibliothèque standard seulement auditable ligne par ligne, zéro dépendance tierce.
- Transport stdio local (mode développement) l'exposition réseau attend le volet sécurisation.
- **Lecture seule** : aucun outil d'écriture le modèle ne peut pas polluer la source de vérité.

Ce qu'il sert

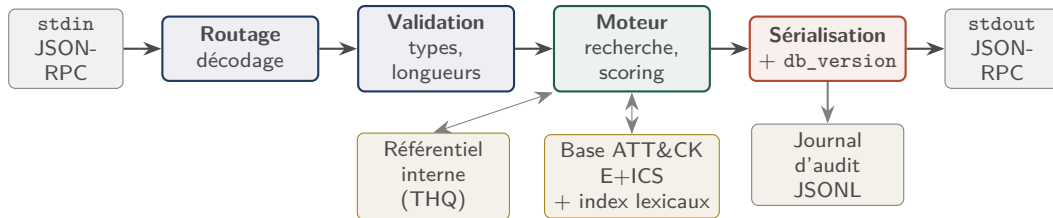
- Base hybride Enterprise + ICS (ATT&CK 19.1) : 27 tactiques, 794 techniques, 176 groupes, 827 logiciels, 96 mitigations.
- 14 outils en 4 familles : cycle de mapping, consultation, référentiel interne, exploitation.
- Chaque réponse datée (db_version) + journal d'audit JSONL.

Chaque ligne de cette carte d'identité traduit une exigence de la problématique en décision technique vérifiable.

L'architecture : le trajet d'une requête



L'architecture : le trajet d'une requête



L'idée essentielle

La validation précède toujours le traitement, chaque réponse est datée, chaque appel laisse une trace et le moteur est **indépendant du transport** : passer en réseau n'ajoutera qu'une couche en amont, sans toucher au moteur ni aux réponses.

La méthode encodée : proposer, puis vérifier

- Proposer `search_techniques` retourne des *candidats* : score normalisé $[0..1]$ ($\geq 0,6$ fort ; $< 0,3$ faible) et preuves les mots réellement trouvés.

La méthode encodée : proposer, puis vérifier

- Proposer `search_techniques` retourne des *candidats* : score normalisé $[0..1]$ ($\geq 0,6$ fort ; $< 0,3$ faible) et preuves les mots réellement trouvés.
- Vérifier `get_technique` confirme chaque candidat retenu : définition complète, tactiques, détections, sous-techniques.

La méthode encodée : proposer, puis vérifier

- Proposer `search_techniques` retourne des *candidats* : score normalisé $[0..1]$ ($\geq 0,6$ fort ; $< 0,3$ faible) et preuves les mots réellement trouvés.
- Vérifier `get_technique` confirme chaque candidat retenu : définition complète, tactiques, détections, sous-techniques.
- Règles d'honnêteté la technique parente d'abord ; et « pas de mapping » est une *conclusion valide* : le serveur l'écrit lui-même.

La méthode encodée : proposer, puis vérifier

- Proposer `search_techniques` retourne des *candidats* : score normalisé [0..1] ($\geq 0,6$ fort ; $< 0,3$ faible) et preuves les mots réellement trouvés.
- Vérifier `get_technique` confirme chaque candidat retenu : définition complète, tactiques, détections, sous-techniques.
- Règles d'honnêteté la technique parente d'abord ; et « pas de mapping » est une *conclusion valide* : le serveur l'écrit lui-même.

L'idée essentielle

Cette discipline n'est pas demandée poliment au modèle : elle est **écrite dans la description des outils** elle voyage avec le serveur, versionnée avec le code, identique pour tous les modèles.

Le référentiel interne THQ : étendre ATT&CK sans le trahir

- Des fiches THQxxxx pour les comportements propres à l'organisation toujours rattachées à une technique MITRE.

Le référentiel interne THQ : étendre ATT&CK sans le trahir

- Des fiches THQxxxx pour les comportements propres à l'organisation toujours rattachées à une technique MITRE.
- MITRE d'abord, l'interne ensuite : recherche anti-doublon soumise aux mêmes règles de score et de preuves.

Le référentiel interne THQ : étendre ATT&CK sans le trahir

- Des fiches THQxxxx pour les comportements propres à l'organisation toujours rattachées à une technique MITRE.
- MITRE d'abord, l'interne ensuite : recherche anti-doublon soumise aux mêmes règles de score et de preuves.
- Lecture seule par conception : le modèle *propose* un brouillon ; un humain relit, valide et committe le fichier.

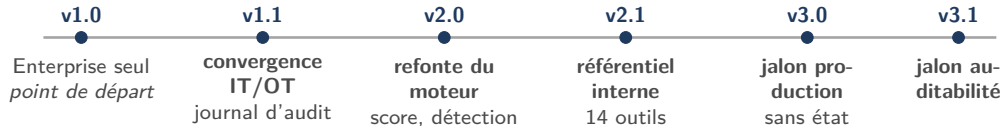
Le référentiel interne THQ : étendre ATT&CK sans le trahir

- Des fiches THQxxxx pour les comportements propres à l'organisation toujours rattachées à une technique MITRE.
- MITRE d'abord, l'interne ensuite : recherche anti-doublon soumise aux mêmes règles de score et de preuves.
- Lecture seule par conception : le modèle *propose* un brouillon ; un humain relit, valide et committe le fichier.

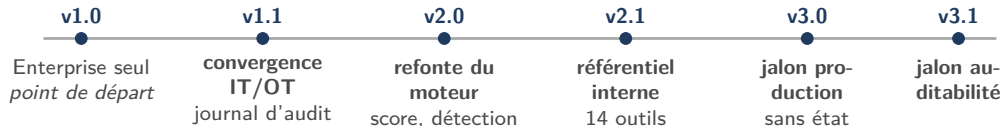
La boucle de renseignement locale

Incident interne → fiche brouillon proposée → validation humaine → le prochain analyste la retrouve, accrochée à la technique MITRE qu'elle précise (`internal_extensions`).

Six versions, chacune née d'un défaut constaté à l'usage



Six versions, chacune née d'un défaut constaté à l'usage



Le fil rouge de tout ce qui suit

Les défauts les plus graves n'ont jamais produit d'erreur : ils se présentaient comme des réponses normales. La *défaillance silencieuse* est le mode d'échec caractéristique d'un composant d'ancrage.

Défaut 1 : Un serveur qui ignorait la moitié du monde

Avant (v1.0)

Matrice Entreprise seule. Sur des journaux industriels (Modbus, automates) : aucun candidat pertinent ou pire, des techniques bureautiques superficiellement voisines.

Défaut 1 : Un serveur qui ignorait la moitié du monde

Avant (v1.0)

Matrice Enterprise seule. Sur des journaux industriels (Modbus, automates) : aucun candidat pertinent ou pire, des techniques bureautiques superficiellement voisines.

Après (v1.1)

Fusion **Enterprise** + **ICS** : chaque objet étiqueté par sa matrice, rattachements cloisonnés « Persistence » existe deux fois (TA0003 $\neq$ TA0110), jamais confondues.

Défaut 1 : Un serveur qui ignorait la moitié du monde

Avant (v1.0)

Matrice Enterprise seule. Sur des journaux industriels (Modbus, automates) : aucun candidat pertinent ou pire, des techniques bureautiques superficiellement voisines.

Après (v1.1)

Fusion **Enterprise** + **ICS** : chaque objet étiqueté par sa matrice, rattachements cloisonnés « Persistence » existe deux fois (TA0003 $\neq$ TA0110), jamais confondues.

L'idée essentielle

Le défaut n'était pas algorithmique, il était **ontologique** : la base interrogée ne couvrait pas le monde observé exactement l'angle mort OT identifié dans l'état de l'art.

Défaut 2 : Une recherche qui trouvait trop, un score qui ne disait rien

Avant (v1.1)

"port" → **264 candidats**, dont *Security Support Provider* et ***Portable Executable Injection***.

Score : un entier sans échelle « 8 »... sur quoi ?

Défaut 2 : Une recherche qui trouvait trop, un score qui ne disait rien

Avant (v1.1)

"port" → **264 candidats**, dont *Security Support Provider* et *Portable Executable Injection*.

Score : un entier sans échelle « 8 »... sur quoi ?

Après (v2.0)

Mots **entiers** + racinisation : "port" → **37 candidats, zéro faux positif**.

Score normalisé [0..1], seuils documentés (0,6 / 0,3), et **preuves** : les mots effectivement trouvés.

Défaut 2 : Une recherche qui trouvait trop, un score qui ne disait rien

Avant (v1.1)

"port" → **264 candidats**, dont *Security Support Provider* et *Portable Executable Injection*.

Score : un entier sans échelle « 8 »... sur quoi ?

Après (v2.0)

Mots **entiers** + racinisation : "port" → **37 candidats, zéro faux positif**.

Score normalisé [0..1], seuils documentés (0,6 / 0,3), et **preuves** : les mots effectivement trouvés.

L'idée essentielle

Un candidat n'est utile que s'il est **interprétable** : un score qui a une échelle, et la preuve de ce qui a réellement correspondu.

Défaut 3 : Le référentiel est vivant : deux pièges silencieux

- **MITRE a restructuré son modèle de détection (v18)** : nos champs se sont vidés sur *toutes* les techniques sans une seule erreur.

Défaut 3 : Le référentiel est vivant : deux pièges silencieux

- **MITRE a restructuré son modèle de détection (v18)** : nos champs se sont vidés sur *toutes* les techniques sans une seule erreur. Corrigé : lecture du nouveau modèle (stratégies → analytics → sources de logs) **0** → **387 sources de données**, 794/794 techniques dotées de détections.

Défaut 3 : Le référentiel est vivant : deux pièges silencieux

- **MITRE a restructuré son modèle de détection (v18)** : nos champs se sont vidés sur *toutes* les techniques sans une seule erreur. Corrigé : lecture du nouveau modèle (stratégies → analytics → sources de logs) **0** → **387 sources de données**, 794/794 techniques dotées de détections.
- **MITRE révoque des techniques** (158 redirections en 19.1) : T1086 répondait « non trouvée » à un rapport CTI de 2019.

Défaut 3 : Le référentiel est vivant : deux pièges silencieux

- **MITRE a restructuré son modèle de détection (v18)** : nos champs se sont vidés sur *toutes* les techniques sans une seule erreur. Corrigé : lecture du nouveau modèle (stratégies → analytics → sources de logs) **0** → **387 sources de données**, 794/794 techniques dotées de détections.
- **MITRE révoque des techniques** (158 redirections en 19.1) : T1086 répondait « non trouvée » à un rapport CTI de 2019. Corrigé : redirection explicite T1086 → « révoquée, consulter T1059.001 ».

Défaut 3 : Le référentiel est vivant : deux pièges silencieux

- **MITRE a restructuré son modèle de détection** (v18) : nos champs se sont vidés sur *toutes* les techniques sans une seule erreur. Corrigé : lecture du nouveau modèle (stratégies → analytics → sources de logs) **0** → **387 sources de données**, 794/794 techniques dotées de détections.
- **MITRE révoque des techniques** (158 redirections en 19.1) : T1086 répondait « non trouvée » à un rapport CTI de 2019. Corrigé : redirection explicite T1086 → « révoquée, consulter T1059.001 ».

L'idée essentielle

S'ancrer sur un référentiel vivant impose de suivre sa vie : versions datées dans chaque réponse, redirections plutôt que silences.

Défaut 4 : Un journal qui ne prouvait pas ce qu'il devait prouver

- Une session de **6 messages** de protocole ne laissait qu'**une** ligne d'audit ; les erreurs, elles, n'en laissaient aucune.

Défaut 4 : Un journal qui ne prouvait pas ce qu'il devait prouver

- Une session de **6 messages** de protocole ne laissait qu'**une** ligne d'audit ; les erreurs, elles, n'en laissaient aucune.
- Corrigé (v3.1) : **chaque phase journalisée** (1 → 6 événements) y compris l'appel d'un outil *inexistant* : l'**hallucination d'outil devient mesurable** depuis le seul journal.

Défaut 4 : Un journal qui ne prouvait pas ce qu'il devait prouver

- Une session de **6 messages** de protocole ne laissait qu'**une** ligne d'audit ; les erreurs, elles, n'en laissaient aucune.
- Corrigé (v3.1) : **chaque phase journalisée** (1 → 6 événements) y compris l'appel d'un outil *inexistant* : l'**hallucination d'outil devient mesurable** depuis le seul journal.
- Enregistrements **enrichis** : identifiant de requête, latence, version du référentiel, résumé des arguments et du résultat et les pertes de traces **se comptent elles-mêmes**.

Défaut 4 : Un journal qui ne prouvait pas ce qu'il devait prouver

- Une session de **6 messages** de protocole ne laissait qu'**une** ligne d'audit ; les erreurs, elles, n'en laissaient aucune.
- Corrigé (v3.1) : **chaque phase journalisée** (1 → 6 événements) y compris l'appel d'un outil *inexistant* : l'**hallucination d'outil devient mesurable** depuis le seul journal.
- Enregistrements **enrichis** : identifiant de requête, latence, version du référentiel, résumé des arguments et du résultat et les pertes de traces **se comptent elles-mêmes**.

L'idée essentielle

Un journal destiné à servir de preuve doit pouvoir déclarer ses propres lacunes : sinon l'absence d'un événement devient indiscernable de sa non-occurrence.

Bilan : ce que le serveur garantit désormais

Garanties acquises

- Couverture **IT/OT** cloisonnée par matrice.
- Candidats **interprétables** : score étalonné + preuves.
- Référentiel vivant **suivi** : versions datées, redirections.
- Traçabilité **de bout en bout**, pertes comptées.

La leçon de méthode

La défaillance silencieuse étant le mode d'échec caractéristique d'un composant d'ancrage, chaque correction est démontrée par un protocole rejouable, la même requête aux deux versions, les deux sorties comparées jamais seulement affirmée.

Bilan : ce que le serveur garantit désormais

Garanties acquises

- Couverture **IT/OT** cloisonnée par matrice.
- Candidats **interprétables** : score étalonné + preuves.
- Référentiel vivant **suivi** : versions datées, redirections.
- Traçabilité **de bout en bout**, pertes comptées.

La leçon de méthode

La défaillance silencieuse étant le mode d'échec caractéristique d'un composant d'ancrage, chaque correction est démontrée par un protocole rejouable, la même requête aux deux versions, les deux sorties comparées jamais seulement affirmée.

Le serveur existe et il est honnête. Reste à le *prouver* l'évaluation et à le *durcir* la sécurisation.